October 2026 security revision

Juan Carlos Nevarez · Gh0stlyKn1ght · github.com/Gh0stlyKn1ght

This edition **changes the four security article sources**. It is a technical revision beyond the earlier extraction/report. Original author credits and exact historical sources remain available. The updated handbook is the current reading path; the earlier 139-page reader remains a historical reference.

Review finding	**Change made**	**Remaining validation**
F01 · Keystore path	Corrected to the root containing `enclaves/`; startup and missing-path cases observed.	Repeat on the target deployment.
F02 · STRIDE error	Corrected Information Disclosure and added an evidence-aware method.	Model review against an actual mission.
F03 · Interoperability promise	Replaced with distribution/vendor scope and tested-combination requirements.	A separately recorded trial for each required combination.
F04 · Ambiguous SROS enabled field	Current records name prerequisites, controls, evidence and residual risk.	Runtime observations; historical table legend stays archived.
F05 · Mixed identity/hardware/ signing roles	Separated DDS credentials, host/ process boundaries, hardware protection and update signing.	Platform-specific key loading, recovery and revocation tests.
F06 · Crystal baseline	Current non-actuating Jazzy/DDS exercise; separate Lyrical platform decision. Historical robot models archived.	Target hardware and package compatibility.
F07 · DDS standard	Added 1.2 reference while retaining the distinction from actual implementation support.	Vendor-specific feature/standard matrix.
F08 · Transport scope	DDS-specific recipe labeled; Zenoh configuration and bridges discussed separately.	Zenoh/bridge deployment tests if selected.
F09 · Scores/evidence	Added 8 structured threat records with owners, prerequisites and residual risk. Old DREAD/RVSS scores remain historical.	Deployment-specific likelihood/ impact and accountable owners.
F10 · Proposed claims	Added explicit evidence states, runtime logs and result templates. Six ROS cases passed.	Separate-authority rejection evidence remains inconclusive.
Print layout	New editable vector figure and portrait updated handbook.	Two proof jobs completed; physical appearance still needs confirmation.

Additional material includes a full lab recipe, restrictive policy, offline schema/XSLT generation and semantic grant checks, eight boundary tests, non-overwriting provisioning script, version capture, and technology recommendations. All five supporting articles now clarify the relevant security boundary: enclave commands, participant mapping, action names, the historical DDS overview, and the network-flow API discussion.

The follow-up repaired the served OAuth surface, pinned the Jekyll build, corrected the fork URL/base path, and checked the site in Chromium. A manual Pages workflow is prepared; publication is separately tracked. This does not imply a current CVE audit, robot deployment or hardware assessment.

The handbook also includes six published middleware case studies by Juan Carlos Nevarez (@Gh0stlyKn1ght), adapted from the pinned ROS2X Research public revision with its CC BY 4.0 attribution. They add remote-permission, control-plane availability and parser/resource examples. These are earlier research observations, not additional passes in the included ROS lab. A fresh public-source checksum audit found six stale README hashes; the evidence files matched. The source-audit section records the required reconciliation.

Recorded lab results

Juan Carlos Nevarez · Gh0stlyKn1ght · October 20, 2026.

What was actually run

The non-actuating lab ran in Ubuntu 24.04 Noble userspace on x86_64 with official ROS Jazzy packages. Tests used a private network namespace with loopback only. This was a software communication test; host isolation and physical robot behavior were outside its scope.

The installed baseline included **Fast DDS 2.14.7**, **rmw_fastrtps_cpp 8.4.4**, and **SROS 2 0.13.6**. Exact Debian package versions, the host kernel, selected settings, public runtime-artifact hashes, and sanitized logs are retained in `runtime-evidence/`. Authority keys and participant private keys remain outside the repository.

Observed ROS cases

Case	Observation	Result
Authorized pair	Seven messages published and received during the observation window; both participants stayed running.	Pass.
Missing enclave	Initialization failed without an artificial test shutdown; exit 250.	Pass.
Forbidden topic remap	Publisher creation failed; no application messages published; exit 250.	Pass.
Wrong identity profile	The talker executable under the listener identity failed to initialize its allowed profile; exit 250.	Pass, for whole-profile rejection.
Focused listener publishing probe	The listener node was constructed successfully, then `/chatter` writer creation was explicitly denied by Fast DDS; probe exit 2.	Pass, for application write denial.
Independently generated authority	Talker published seven messages; listener received zero. Both stayed running, but no explicit authentication rejection appeared in default logs.	**Inconclusive** for the claimed rejection mechanism.
Authorized control repeated afterward	Seven messages published and received after the negative cases.	Pass.

Six of seven ROS cases passed. The complete suite is not reported as passing. The separate-authority observation meets the no-delivery expectation but does not by itself establish why delivery stopped.

A supplementary native Fast DDS probe recorded `AUTHENTICATION_ACCEPTED` for the trusted peer. The same probe with the independently created authority recorded neither acceptance nor rejection in its eight-second window. That result is retained, not converted into a rejection claim. Further discovery/handshake instrumentation is needed before closing this evidence gap.

The actual permissions XML generated by the installed SROS 2 package also passed the exact two-grant checks used by the offline example; see `runtime-permission-check.json`.

The two runtime enclave keys had mode `0600` in this environment. That checks group/other mode bits; it does not establish that privileged code, same-process code, mounts, or a different deployment account cannot access them.

Reproduce the software tests

On a prepared Jazzy host, provision two new lab directories using the documented setup script. Then run the runner with their separate keystores and a new output directory:

```
python3 examples/security-lab/run_runtime.py \
  --keystore /absolute/first/keystore \
  --untrusted-keystore /absolute/second/keystore \
  --output /absolute/new-results-directory
```

Run only on a non-actuating lab system. The runner uses domain 42 and localhost discovery, scopes shutdown to the processes it starts, refuses to reuse an output directory, and returns a nonzero status if any case fails or is inconclusive. Review the logs and version manifest before comparing results across machines.

The optional `authentication_probe.cpp` targets the Fast DDS 2.14 API and requires that version's headers/libraries and a C++ compiler. Its native callback observations are separate from the ROS application delivery cases; it does not replace them.

Limits of these observations

The separate-authority case remains inconclusive. Further tests are needed for revocation, expiry, credential renewal and recovery, hardware-backed keys, privileged-host isolation, bounded overload behavior, and packet-level confidentiality. No physical robot or actuator was tested. The run does not establish a vulnerability assessment or compliance conclusion.

Libraries and technology choices

Juan Carlos Nevarez · Gh0stlyKn1ght · Reviewed October 20, 2026.

Use SROS 2 for DDS identity and permissions, a bounded XML checker for the example policy, and an editable threat register and architecture diagram. The choices below distinguish tools used in the lab from deployment options that need a target-system trial.

Tools used in the lab and threat model

Technology	Purpose and reason	Limit
SROS 2 policy 0.2.0	ROS-oriented privileges and a path to signed DDS permission artifacts. The offline example uses a pinned upstream schema and transform.	A valid policy and signed file still need actual middleware enforcement tests.
Python + lxml	Schema validation, the upstream XSLT, exact grant assertions and input-boundary checks. Schema resolution is local; DTDs and XInclude are rejected for this example.	The checker accepts this defined format, not arbitrary external XML/XSLT.
Graphviz DOT → SVG/PDF	Editable architecture source with explicit processes, assets and trust boundaries.	Diagram boundaries are design claims until their controls are verified.
JSON threat register and result template	Stable IDs, prerequisites, owners, evidence states and residual-risk notes, rendered into printable records.	No automatic risk score substitutes for a deployment-specific judgment.

Primary documentation: SROS 2, lxml resolution and XSLT access control, and Graphviz SVG.

Middleware and platform decisions

For the included exercise: use Jazzy on Ubuntu 24.04 with `rmw_fastrtps_cpp`. This keeps the commands and policy aligned with a reviewed official tutorial and the pinned Jazzy transformation. Capture installed package versions; do not infer package versions from the ROS distribution name. The isolated run recorded six passed ROS cases and one inconclusive separate-authority case; consult the runtime observations before relying on a particular claim.

For a new long-lived robot: evaluate Lyrical on Ubuntu 26.04 when its hardware/application dependencies are supported. Lyrical's official support horizon is May 2031; Jazzy remains listed through May 2029. The decision depends on drivers, vendor support, package availability, and a measured migration run. See the official release table and Lyrical platform matrix.

Fast DDS is a suitable starting point for this DDS-focused lab. **Cyclone DDS** is a credible alternate implementation for a separately tested deployment; both document security plugins and signed governance/permissions. Neither is declared “more secure” here, and no performance benchmark was run. Choose based on supported packaging, required features, operational evidence and vendor support. The Jazzy tutorial does not support secure cross-vendor communication. Sources: Fast DDS security, Cyclone DDS security, and Jazzy tutorial.

Zenoh is an option when its routing/topology model fits the application. The current `zenoh_security_tools` can generate session configs using SROS 2 policy and keystore material. Its router/session settings and bridge boundaries need their own review; switching `RMW_IMPLEMENTATION` is not a complete migration of DDS security. Source: official Zenoh security tools. This option is documented, not installed or validated in this package.

Useful next-stage tools

- **OWASP Threat Dragon desktop:** useful when several people want a visual data-flow editor with threat/remediation records and local files. Keep the JSON register as a reviewable artifact and check export compatibility with old diagrams. It is optional; the authored DOT/SVG figure already works offline. Threat Dragon documentation.
- **Syft + Grype:** useful for dependency inventory and vulnerability triage of a selected deployment image/filesystem. Record tool versions, artifact digest, database age and exceptions. An SBOM is not evidence that a vulnerability is exploitable; a clean scan does not prove safety. These tools were researched, not run. Syft, Grype.
- **Cosign:** useful when an actual release pipeline needs artifact-signature verification. Define the accepted signing identity/issuer or trusted key and verify the intended artifact digest. Keep this release-signing trust separate from DDS identities. No signing integration was configured. Cosign verification.

The most useful next investment is stronger instrumentation for the inconclusive separate-authority case, followed by a small current-robot case study. Introducing more tooling before those results would not strengthen the handbook's evidence.

Published research source review

The handbook now includes a teaching adaptation of six public ROS2X Research case studies by Juan Carlos Nevarez (@Gh0stlyKn1ght). The reviewed public revision is `30ce3dd0eb22b384f010e5f9679e459517be6965`. The case studies support implementation-specific threat and evidence discussions; they do not change the handbook's six-pass, one-inconclusive runtime result.

Checksum reconciliation needed

A read-only check recomputed all 152 entries in the six published case checksum manifests. **146 entries matched; six did not.** Every mismatch is a case `README.md`. The listed logs, captures, harness sources and other evidence files matched their recorded hashes.

All six recorded README hashes match their versions immediately before public commit `e3985a8`, which added architecture diagrams and editorial material. The current READMEs were changed without corresponding checksum updates. This accounts for the observed drift; it does not justify reporting all current published checksums as passing.

The historical manifests have not been modified. A dated reconciliation that identifies the original manifest, pinned source commit, current README hashes and editorial change is needed before describing the current source bundle as fully checksum-verified. `research-source-review.json` records the observed hashes and the history comparison.

The CVE-2023-39948 manifest also retains `release_status: reviewed` even though the case is present in the public repository and the source registry records external publication. Reconcile this metadata through the same versioned process.

Scope of this review

The review read published case documentation and recomputed file hashes. It did not rerun the experiments, validate a current dependency inventory, or reassess vendor patch coverage. No private research record, raw evidence, withheld case or manuscript text was copied into the handbook.

Remaining work and acceptance criteria

The four core security articles and five supporting passages have been updated. The lab has six passed runtime cases and one inconclusive case. The following work remains; the completed source revision should not be confused with a validated robot deployment.

Priority	Open work	Evidence needed to close it
1	Explain the independent-authority result.	Correlated discovery/handshake diagnostics showing where the untrusted peer is rejected, with a successful trusted control under the same settings. Zero delivered messages alone is insufficient.
2	Add a current robot case study.	A named mission, hardware, OS/ROS/RMW versions, topology, assets and trust boundaries; accountable owners, exposure/impact rationale and residual risk for each threat. The present example has no actuators.
3	Validate operational controls on that target.	Recorded tests for credential expiry, renewal, revocation and recovery; host/account access to keys; traffic protection; overload limits and recovery. Hardware-backed keys need their own integration test if selected.
4	Assess the actual release dependencies.	An inventory of the selected image and packages plus current vulnerability triage tied to its digest and versions. No SBOM or vulnerability scan was run in this revision.
5	Complete the publication checks.	A dated reconciliation of the six public research README checksum mismatches, a successful remote CI run and, after a publishing target is chosen, a deployed commit and PDF hash matching the approved revision. Local site/browser checks are complete; the current work has not been pushed or deployed.
6	Confirm the final reading experience.	Physical observation of the portrait and diagram proofs for orientation, clipping and readability. Two printer

Priority	Open work	Evidence needed to close it
		jobs completed; paper appearance remains unconfirmed. Tagged output is present, but PDF/UA and screen-reader conformance have not been assessed.

Additional middleware/platform trials are conditional on the deployment choice: Lyrical, Cyclone DDS, Zenoh and cross-vendor combinations were not runtime-tested here. They should not delay the documented Jazzy/Fast DDS teaching exercise unless the project needs them.

Before publication, reconcile the public research writeup checksums without rewriting historical evidence. The next technical step is to close the independent-authority evidence gap. A real robot model and its bounded validation plan follow once the target platform and mission are known.